# Semana 09 — Triage estatico sin ejecutar la muestra

Grupo 2 · rol Rojo · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

| | |
|---|---|
| **Curso** | CYBERSEGURIDAD — Ciberseguridad Aplicada |
| **Semana** | 09 de 10 |
| **Fase** | 4 — Forense y respuesta a incidentes |
| **Grupo** | 2 |
| **Rol** | Rojo |
| **Entrega** | GitHub, carpeta semana_09/ |
| **Corte** | Domingo 23:59 de la semana correspondiente; lo posterior no se corrige. |

## 1 Tu rol en la práctica

Ejecuta la técnica ofensiva sobre el objetivo autorizado: prepara el entorno, lanza el ataque, registra comandos y payloads, y guarda cada salida con su hash.

- Confirmar el objetivo autorizado y preparar el entorno antes de la primera captura.
- Ejecutar la técnica de la semana en el orden de los pasos y guardar cada salida cruda con su hash.
- Redactar la reproducción: comando, salida esperada y salida obtenida, sin retocar la evidencia.

## 2 Qué aporta este rol al entregable

Evidencia cruda en semana_NN/evidencia y el apartado de reproducción del informe.

## 3 Ejemplo paso a paso

El rol Rojo describe la muestra sin ejecutarla: tipo de archivo, cabeceras, cadenas y hash. La regla es simple: se lee, no se corre.

### 3.1 Identificar el tipo y calcular el hash

El tipo se lee de la cabecera y se contrasta con la extension. El hash es la identidad de la muestra y se calcula antes de cualquier analisis.

```
mkdir -p semana_09/evidencia
file muestra.bin | tee semana_09/evidencia/tipo.txt
sha256sum muestra.bin | tee semana_09/evidencia/sha256.txt
md5sum muestra.bin | tee semana_09/evidencia/md5.txt
```

### 3.2 Leer cabeceras sin ejecutar

Para un ELF se leen cabecera y secciones; para un documento se revisan objetos embebidos. Nada de abrir el archivo con el programa que lo interpretaria.

```
readelf -h muestra.bin | tee semana_09/evidencia/elf.txt 2>/dev/null ||
    true
xxd -l 128 muestra.bin | tee semana_09/evidencia/hex.txt
```

### 3.3 Extraer cadenas y clasificarlas

Las cadenas se agrupan por interes: rutas, dominios, comandos, mensajes. La lista cruda va como evidencia; la clasificacion va en el informe.

```
strings -n 6 muestra.bin > semana_09/evidencia/strings.txt
grep -Ei 'http|curl|wget|/tmp/|base64|chmod|system' \
  semana_09/evidencia/strings.txt | head -30 \
  | tee semana_09/evidencia/indicadores.txt || true
```

### 3.4 Consultar reputacion sin subir la muestra

Se consulta solo el hash. Si no hay API disponible, se documenta como no verificado en lugar de inventar un veredicto.

### 3.5 Artefacto, hallazgo y valor probatorio

**Artefacto, hallazgo y valor probatorio**

| Artefacto | Hallazgo | Valor probatorio | Accion |
|---|---|---|---|
| Tipo y hash | ELF de 64 bits con SHA-256 propio | Identidad de la muestra | Registrar y buscar reputacion |
| Cabecera | Entrada y secciones legibles | Estructura del binario | Documentar |
| Cadenas | Rutas y comandos de descarga | Indicio de funcionalidad | Correlacionar con la regla |
| Reputacion | No consultada por falta de API | No verificado | Declarar limitacion |

La columna de valor probatorio distingue indicio de prueba; un string suelto es indicio.

## 4 Qué guardar en el repositorio

Se entrega el informe de triage con tipo, hashes, cabeceras, cadenas clasificadas y la declaracion de lo que no se pudo verificar.

```
semana_09/
|-- informe.md
|-- muestra.bin
|-- evidencia/
|   |-- tipo.txt
|   |-- sha256.txt
|   |-- elf.txt
|   |-- hex.txt
|   |-- strings.txt
|   `-- indicadores.txt
`-- README.md
```

- La muestra no se ejecuto en ningun momento.
- El hash se calculo antes de abrir el archivo con otras herramientas.
- Las cadenas estan clasificadas, no solo volcadas.
- Lo no verificado esta declarado.

# 5 Cómo se corrige

| Criterio | Peso |
|---|---|
| Playbook operativo con fases y responsables | 3,0 |
| Triage estático completo y sin ejecutar la muestra | 2,5 |
| Regla YARA que detecta la muestra | 2,0 |
| Post mortem con mejoras priorizadas | 1,5 |
| Cumplimiento de las reglas de manejo de muestras | 1,0 |
| **Total** | **10,0** |

- La muestra no se abre con el programa que la interpreta, ni con doble clic.
- {'Subir la muestra a un servicio externo puede exponer datos': 'solo se consulta el hash.'}

**Recuerda**

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.